

Towards a Unified Civic Identity Stack: Integrating Nepal’s National Identity Card (NID) with Cross-Domain Government Services

Sakshyam Banjade

Independent Researcher, Kathmandu, Nepal

hi@sakshyambanjade.com.np | ORCID: 0009-0001-4283-9678

2026

Abstract

Nepal’s National Identity Card (NID) programme enrolled over 17.2 million citizens by mid-2025, yet only 2.3 million had collected their cards and the NID remained connected to fewer than ten services nationally. This paper asks: under what architectural conditions can a foundational identity system achieve cross-domain interoperability without creating exclusion or surveillance risk? Drawing on infrastructure theory, data justice, and digital era governance frameworks, it analyses six national digital identity systems to derive two design hypotheses: federated architectures correlate with lower breach severity, and citizen audit visibility correlates with voluntary adoption. From these design hypotheses and Nepal’s constitutional constraints—including the Supreme Court’s 2024 jurisprudence on citizenship certificate primacy—the paper proposes the *Nepal Civic Identity Stack*: a conceptual six-layer federated architecture built on open standards (OpenID Connect, MOSIP, X-Road) with a citizen-centric consent layer. Eight integration domains are prioritised through a scoring matrix; legal analysis identifies critical gaps in Nepal’s Privacy Act 2075 using GDP-normalised penalty comparisons and Nissenbaum’s contextual integrity framework. The paper advances the *Federated Legibility Principle* as a transferable design heuristic for fragile-federation contexts. Limitations, including the absence of primary fieldwork and the small-N comparative sample, are acknowledged explicitly.

Keywords: digital identity; e-governance; Nepal NID; federated architecture; interoperability; data protection; MOSIP; OpenID Connect; civic services

1. Introduction

A national identity system is, at its core, a legibility infrastructure: it renders citizens legible to the state across contexts, and—when designed well—makes the state legible to citizens in return. James Scott’s concept of high-modernist state-making [28] frames such systems as double-edged instruments: they enable welfare distribution and service efficiency on one hand, and surveillance and exclusion on the other. The design question is not whether to build state legibility infrastructure, but *under what architectural conditions* it can achieve interoperability without producing exclusion, coercion, or breach of privacy. Nepal’s National Identity Card (NID) programme makes this question urgent and tractable.

Nepal enacted the National Identity Card and Civil Registration Act, 2076 (2020)—hereafter the *NID Act*—creating the Department of National ID and Civil Registration (DoNIDCR) and mandating biometric enrolment for all citizens aged sixteen and above. By mid-2025, 17,213,550 citizens had been enrolled. Yet only 2,312,484 had collected their physical cards [10, 11]—approximately 13 per cent—and the NID remained connected to fewer than ten services nationally, while Singapore’s Singpass spans more than 2,000 [4]. The gap between enrolment and utility is not incidental; it reflects the absence of the interoperability layer that transforms an identity artefact into a civic infrastructure. The World Bank’s Digital Public Infrastructure (DPI) framework identifies this interoperability layer—shared open standards, API governance, and consent architecture—as the critical missing component in identity ecosystems that stall after initial enrolment [21].

A Cabinet decision of 6 June 2024 announced full NID-service integration within one year. A Supreme Court interim stay issued in August 2024 and lifted in January 2025 exposed the constitutional tension between mandating NID use and the primacy of the citizenship certificate as foundational legal identity [12]. The challenge is therefore simultaneously architectural, legal, and institutional.

Research Questions

This paper addresses four questions:

- RQ1.** Under what architectural conditions can a foundational identity system achieve cross-domain interoperability without creating exclusion or surveillance risk?
- RQ2.** What design principles does comparative analysis of mature national digital identity systems yield for Nepal’s specific legal and institutional context?
- RQ3.** How should the Nepal Civic Identity Stack be structured to accommodate the Supreme Court’s constitutional constraint that NID must complement, not displace, existing legal identity documents?
- RQ4.** What legal reforms are necessary and sufficient to ground NID integration in citizen rights rather than administrative convenience?

Contributions and Scope

This paper makes three contributions. First, a theoretically grounded comparative analysis of six national digital identity systems, yielding two design hypotheses and the *Federated Legibility Principle* as a transferable design heuristic (Section 6.2). Second, a conceptual federated architecture—the *Nepal Civic Identity Stack*—specifying how the NID should integrate with eight civic service domains using open standards and a consent-based API ecosystem. Third, an analysis of the legal reforms necessary to ground that architecture in constitutional rights.

This paper does *not* address integration with Nepal’s health or education sectors, which present distinct legal frameworks (Health Policy 2076, Education Act 2028) and warrant separate treatment. It also does not address cross-border identity federation for Nepali diaspora workers, which raises bilateral treaty questions beyond the scope of domestic service integration.

Acronyms. NID = National Identity Card; NIN = National Identity Number (11-character unique identifier); DoNIDCR = Department of National ID and Civil Registration; OIDC = OpenID Connect; MOSIP = Modular Open Source Identity Platform; PKI = Public Key Infrastructure; KYC = Know Your Customer; DPI = Digital Public Infrastructure; DPIA = Data Protection Impact Assessment; CRVS = Civil Registration and Vital Statistics; LRIMS = Land Records Information Management System; BAFIA = Banks and Financial Institutions Act; DOLMA = Department of Land Management and Archive; DoTM = Department of Transport Management; IRD = Inland Revenue Department; SSF = Social Security Fund.

2. Problem Statement

Nepal’s public service ecosystem remains fundamentally fragmented. Citizens carry multiple siloed identity documents—the citizenship certificate, passport, voter ID, land ownership certificate (*lalpurga*), and bank KYC records—each issued by a separate agency with no interoperability. The Land Records Information Management System (LRIMS), operated by DOLMA, is disconnected from the NID database; a land registration requires a citizenship certificate, photographs, tax clearance, land maps, and ownership certificates, each processed at a different office [15].

As of mid-2025, DoNIDCR had enrolled 17,213,550 citizens and printed 6,235,599 cards, of which 6,204,448 were dispatched to districts and 1,518,027 distributed door-to-door. Total cards in citizens’ possession stood at 2,312,484—approximately 13 per cent of total enrolled [11]. This figure includes both door-to-door deliveries and self-collection at district offices; the two channels together account for the full 2.3 million. A separate measure shows that 65.66 per cent of citizens whose cards had been printed had not collected them, reflecting a widespread perception that the card offers no practical service advantage [10].

The Cabinet decision of 6 June 2024, gazetted on 24 June 2024, mandated full NID-service integration within one year. The Department of Foreign Affairs (DoFA), Land Revenue Offices, DoTM, Civil Registration Offices, commercial banks, and local governments have yet to achieve decisive integration [11]. The Supreme Court’s August 2024 interim stay—holding that services historically delivered on citizenship could not be made conditional on NID while card distribution remained incomplete—added legal uncertainty to institutional inertia [12]. The stay was lifted on 19 January 2025, but the underlying constitutional tension remains.

Nepal’s UN E-Government Development Index (EGDI) score in 2024 was 0.5781, ranking 119th of 193 countries [22]. To contextualise: Bangladesh ranked 111th (EGDI 0.6138) and Rwanda 138th (EGDI 0.5281) in the same survey. Nepal thus sits at the lower-middle tier of e-governance readiness among income-comparable peers—below Bangladesh but ahead of Rwanda, two countries whose identity systems are analysed in Section 3. Mobile subscriptions stand at 141 per 100 people and mobile broadband at 131.5 per 100 people—high SIM penetration in a shared-device culture. Internet penetration is approximately 56 per cent, with a significant urban-rural divide. These conditions create a genuine opening for mobile-channel identity services, but passive infrastructure growth will not by itself drive adoption.

We define the *integration gap* as the delta between enrolled population and active service utilisation, mediated by three measurable variables: (1) physical card delivery rate (currently 13 per cent); (2) legal interoperability mandates (present for fewer than five of eight target domains); and (3) API infrastructure maturity (gateway and NNAS not yet deployed). Closing this gap is the central challenge the Nepal Civic Identity Stack addresses.

Table 1 presents a *theoretical minimum burden model* derived from the statutory document requirements for each transaction under current Nepali law. The visit count lower bound equals the number of distinct issuing authorities whose documents are required by law; the day count lower bound reflects known minimum processing times from published government guidelines and media reports [11, 15]. This approach grounds the estimates in verifiable legal requirements rather than survey data, making them a defensible floor rather than a mid-range approximation. Actual citizen experience is likely worse due to queuing, document rejection, and travel costs; a rigorous primary study quantifying the true burden remains a priority for future empirical work.

3. Literature Review: Theoretical Background and Comparative Analysis

3.1 Theoretical Background

This paper draws on three bodies of literature. *Infrastructure theory* conceptualises identity systems not as isolated tools but as shared sociotechnical substrates whose value emerges from use across many domains [29]. Frischmann’s framework highlights that infrastructure generates positive externalities precisely when it is governed as a

Table 1. Theoretical minimum citizen burden per transaction, derived from statutory document requirements. Visit count = number of distinct issuing authorities required by law. Day count = minimum published processing time.

Transaction	Visits (min.)	Days (min.)
Citizenship certificate	3–5	15–30
Passport issuance	2–3	30–60
Land registration	4–6	7–21
Bank account opening	2–3	1–3
Marriage registration	2–3	3–7
PAN registration (IRD)	2	1–5
Social security enrolment	3–4	7–15
Driving licence (DoTM)	3–4	15–45

Sources: Statutory document requirements per relevant Acts; processing times from [11, 15] and published government guidelines. These are lower bounds; actual burden is typically higher.

commons—open, non-excludable, and layered—rather than as a proprietary platform. Nepal’s NID, to realise its potential, must function as infrastructure in this sense rather than as a siloed government database.

Data justice theory (Dencik et al.) situates identity systems within power relations: who is rendered legible to whom, on whose terms, and with what recourse for those who are misidentified or excluded [30]. This lens motivates the paper’s emphasis on fallback mechanisms, consent architecture, and citizen audit rights—not as optional features but as structural prerequisites for legitimate deployment.

Digital era governance (Margetts and Dunleavy) argues that the defining challenge of large-scale government IT is not technical but organisational: the integration of legacy silos across agencies with divergent incentive structures [31]. This explains why Nepal’s Cabinet mandate has not automatically produced integration: institutional inertia and turf protection are predictable features of multi-agency systems, not anomalies.

The World Bank’s ID4D (Identification for Development) framework provides a practical bridge between theory and implementation, specifying ten principles for inclusive digital identity: universal coverage, free from discrimination, voluntary use, unique, robust, secured, accessible, interoperable, privacy-respecting, and providing recourse [21]. The Nepal Civic Identity Stack is designed to satisfy all ten.

3.2 Comparative Case Selection

Six countries were selected on four explicit criteria: (1) availability of published deployment data sufficient to assess architecture, adoption, inclusion outcomes, and breach history; (2) representation of at least one federated and one centralised architecture; (3) geographic spread including at least one developing-economy peer for Nepal; and (4) at least one documented breach or failure case, providing negative evidence

alongside positive models. Estonia provides the federated high-income benchmark; India the centralised scale benchmark; Singapore the federated API model with near-universal adoption; Bangladesh and Pakistan two independent developing-economy centralised-with-breach cases (satisfying C3 and C4 without duplication); and Rwanda the developing-economy PPP positive case. Kenya’s Huduma Namba, Philippines’ PhilSys, and Thailand’s ThaID were excluded for incomplete published deployment data at time of writing.

3.3 Estonia — X-Road

Estonia’s X-Road connects over 900 organisations and 3,000 e-services through a *federated* data-exchange layer in which no participant relinquishes custody of its own data. Each institution runs a security server mediating encrypted, mutually authenticated, and digitally signed requests over a common protocol [1]. Citizens authenticate via chip-based national identity card, Mobile-ID, or Smart-ID, all underpinned by PKI. A blockchain-anchored audit trail records every data-access event, and a citizen portal allows individuals to see which agency accessed which attribute and when. X-Road processes approximately 2.2 billion transactions per year, saving an estimated 2,589 person-years of administrative time annually [2]. For Nepal, the architectural lesson is clear: federated interoperability builds institutional trust, avoids single-point-of-failure risk, and is compatible with progressive, agency-by-agency adoption.

3.4 India — Aadhaar and India Stack

India’s Aadhaar is the world’s largest biometric identity system, with over 1.38 billion numbers issued [3]. The India Stack—comprising Aadhaar, the Unified Payments Interface, DigiLocker, and eSign—constitutes a full DPI layer. Direct benefit transfers under the JAM Trinity (Jan Dhan, Aadhaar, Mobile) reduced welfare leakage by an estimated 10–20 per cent [25]. However, the Supreme Court’s *K.S. Puttaswamy v. Union of India* (2018) recognised privacy as a fundamental right and restricted mandatory Aadhaar linkage for private services. Documented authentication failures have excluded elderly citizens and manual labourers with worn fingerprints, and multiple data leaks have exposed personal records [24]. The lesson for Nepal is cautionary: centralised biometric systems achieve scale but generate disproportionate, irreversible breach risk, since biometric credentials cannot be reissued.

3.5 Singapore — Singpass and MyInfo

Singapore’s Singpass provides single sign-on to over 2,000 services from 140 government agencies and private organisations, with 97 per cent penetration among eligible citizens and permanent residents aged 15 and above [4]. The APEX API gateway mediates cross-agency data exchange; the MyInfo service pre-fills application forms with government-verified attributes, implementing a genuine once-only principle. Face-scan images are retained for only 30 days. Financial institutions reported a reduction in onboarding

costs of approximately USD 36 per customer [5]. Singapore demonstrates that federated identity combined with strong legal trust frameworks and attentive user-experience design drives near-universal adoption.

3.6 Bangladesh — NID

Bangladesh’s NID issues smart cards to virtually all voting-age citizens. The Birth Registration Information System exchanges data with 22 government agencies [6]. A persistent challenge is a recursive prerequisite: birth certificates require NID verification and NID registration requires birth certificates, creating foundational enrolment exclusions. A 2025 data-contractor breach prompted cancellation of that contractor’s API access, illustrating that governance and audit frameworks must precede scale.

3.7 Pakistan — NADRA

Pakistan’s Computerised National Identity Card, issued by the National Database and Registration Authority (NADRA), covers over 120 million citizens. A 2025 incident exposed biometric records of millions through an unauthorised third-party channel, demonstrating the severe and irreversible consequences of concentrated storage [7]. The 2025 Digital Nation Act establishes a National Data Exchange Layer modelled on X-Road [8], representing a policy correction toward federation after that experience.

3.8 Rwanda — Irembo

Rwanda’s IremboGov portal provides digital access to over 248 government services through a public-private partnership, processing more than five million citizen transactions annually [9]. A Government Enterprise Service Bus launched in April 2022 enables ask-once, use-many data sharing with citizen consent. Average service delivery time fell from five days to 24 hours. Agent networks in all 30 districts bridge the digital divide for citizens without smartphones. Rwanda demonstrates that rapid service digitalisation is achievable in a developing-economy context when funding models, service design, and inclusive access are addressed concurrently.

3.9 Comparative Summary and Propositions

Table 2 summarises the six systems across five dimensions including inclusion outcomes and breach incidents.

The cross-case pattern supports two design hypotheses that motivate the Nepal architecture:

Design Hypothesis H1. Federated architectures correlate with lower breach severity: among the six cases, all documented major breaches occurred in centralised systems (India, Bangladesh, Pakistan). No federated system (Estonia, Rwanda) has suffered a comparable incident.

Design Hypothesis H2. Citizen audit visibility correlates with voluntary

Table 2. Comparative analysis of national digital identity systems. “Eligible pop.” for Singapore: citizens and permanent residents aged 15+ [4].

Country	Architecture	Adoption	Inclusion outcome	Breach incident
Estonia	Federated	2.2B txns/yr	High; citizen audit visibility	None documented
India	Centralised	1.38B enrolled	Moderate; exclusion documented	Multiple leaks
Singapore	Central IdP + federated APIs	97% eligible pop.	High; appeals mechanism	Minor
Bangladesh	Centralised	Near-universal adults	Moderate; circular exclusion	Contractor breach 2025
Pakistan	Centralised	120M+ covered	Moderate	Major breach 2025
Rwanda	ESB (PPP)	5M+ txns/yr	High; agent network inclusion	None documented

adoption rates. Estonia and Singapore—the two systems with transparent citizen-facing audit portals—both achieve the highest voluntary adoption rates. The proposed Nepal Consent Dashboard (Layer 5) operationalises this principle.

These are motivating observations, not statistically validated claims. With six cases selected partly on data availability (a non-random procedure), causal inference is not possible and even correlational claims must be treated cautiously. The small-N limitation is acknowledged explicitly here rather than deferred: H1 rests on a perfect split (three federated systems, zero breaches; three centralised systems, multiple breaches), which is suggestive but could reflect reporting differences or recency bias rather than an architectural effect. H2 rests on two cases (Estonia, Singapore). Both hypotheses are offered as motivating design rationale, not as established empirical regularities. They identify mechanisms—reduced blast radius from federation; trust-building from transparency—that are theoretically well-grounded [29, 30] even if the six-case sample cannot confirm their causal force.

4. Nepal NID: Current State

4.1 Enrolment and Delivery (mid-2025)

As of mid-April 2025, DoNIDCR had enrolled 17,213,550 citizens and printed 6,235,599 cards, of which 6,204,448 were dispatched to districts. A door-to-door campaign distributed 1,518,027 cards. Total cards in citizens' possession stood at 2,312,484—approximately 13 per cent of total enrolled [11]. The World Bank independently reported a 66 per cent pick-up shortfall as of mid-2025 [21].

The Nagarik App has accumulated 55.2 million cumulative installs (49.1 million Android, 6.1 million iOS) [13]. This figure exceeds Nepal's population of approximately 30 million and reflects cumulative downloads over several years in a shared-device environment; it should not be read as equivalent to unique active users. Monthly active user data is not publicly disclosed. The app currently offers 62 services from 35 government entities.

4.2 Legal Framework: NID Act 2076

The National Identity Card and Civil Registration Act, 2076 (2020) mandates biometric NID issuance to all Nepali citizens aged 16 and above [14]. Key provisions relevant to integration include: Section 3 (establishes DoNIDCR); Section 4 (mandates universal issuance); Section 11 (specifies biometric and demographic data collection); Section 19 (authorises cross-service identity verification); Section 28 (penalties up to five years' imprisonment or NPR 500,000 for unauthorised data access); and Section 29 (security obligations on DoNIDCR). The Act does not contain an explicit consent architecture for cross-domain data sharing, does not specify purpose-limitation principles, and does not establish an independent oversight body.

4.3 Current Service Integrations and Remaining Gaps

The NID is mandatory for: passport applications (DoFP); new bank account and SIM registration (from January 2025); Social Security Fund contributor registration; and select scholarship schemes. Services that continue to require the citizenship certificate without NIN integration include: land registration (DOLMA/LRIMS), marriage registration at local bodies, PAN registration (IRD), vehicle registration (DoTM legacy workflows), and most local government certifications. The DoFP permits overseas applicants to omit the NIN field in passport applications, confirming that even nominally integrated services lack real-time API verification [17].

4.4 Political Economy of Integration Stall

The Cabinet mandate of June 2024 has not produced decisive integration for reasons that are institutional as much as technical. Land Revenue Offices resist NIN as the canonical owner identifier because a unified record would expose title irregularities currently obscured by siloed registers—a dynamic reported across South Asian land

administration reform attempts [27]. IRD has no structural incentive to merge PAN with NIN while PAN registration fees, collected under Income Tax Act 2058 Section 83, constitute a discrete revenue line; the 2024 IRD annual report recorded over NPR 2 billion in administrative fees, a figure that would be compressed by NIN-linked automatic PAN issuance [11]. Local bodies lack IT staff—The Rising Nepal reported in 2025 that fewer than 30 per cent of ward offices had a dedicated IT officer [11]—and fear that NID integration will trigger central audits of their certification workflows. Commercial banks made compliance investments in citizenship-certificate KYC infrastructure after NRB Unified Directives 2080 and face transition costs estimated at NPR 50–100M sector-wide [11]. This is not a coordination failure resolvable by a single gazette notification; it requires sequenced incentive redesign—principally, demonstrating to each agency that NID integration increases rather than reduces its operational authority. The federated architecture proposed in Section 6 addresses this directly: agencies retain custody of their own data and are not subordinated to a central registry.

4.5 Supreme Court Jurisprudence and Constitutional Constraints

On 23 August 2024 the Supreme Court issued an interim order staying the Cabinet mandate, holding that services historically delivered via citizenship certificate could not be made conditional on NID while card distribution remained incomplete [12]. The Court’s reasoning drew on two constitutional provisions: Article 28 of the Constitution of Nepal 2015 (right to privacy), which the Court interpreted as encompassing a right not to be compelled to disclose biometric data as a prerequisite for accessing constitutional entitlements; and Article 17 (right to equality), under which the NID mandate, applied before near-universal card delivery, discriminated between citizens who had and had not been able to collect their cards. The Court found that making welfare services conditional on a card fewer than one in seven enrolled citizens had received was constitutionally disproportionate.

On 19 January 2025 the petition was dismissed and the mandate cleared, but the jurisprudence establishes a binding architectural constraint: NID integration must *complement*, not replace, existing legal identity documents. Every NID-integrated service must maintain a fallback pathway accepting the citizenship certificate until card delivery reaches a constitutionally sufficient threshold. This paper recommends two distinct thresholds: **75 per cent** as the gate for expanding mandatory NID requirements to additional service domains (Phase 2 trigger), because the Court’s 2024 reasoning concerned a majority without cards; and **95 per cent** adult coverage as the gate for retiring the citizenship-certificate fallback entirely. Neither figure is formally mandated by the Court—both are this paper’s analytical recommendations grounded in the proportionality reasoning the judgment applied. The consent architecture proposed in Layer 5 of the Nepal Civic Identity Stack is designed in direct response to this constraint: consent cannot be coercive when a genuine, legally valid alternative exists.

5. Integration Domains

For each domain the analysis covers the current system, specific legal and technical barriers, and the proposed NID integration pathway. All proposals presuppose the federated architecture described in Section 6.

Table 3 scores each domain on four dimensions to explain the sequencing adopted in the Phase 1–3 roadmap (Section 8). Scores are 1 (low) to 3 (high) for citizen impact, and 1 (low barrier) to 3 (high barrier) for the remaining dimensions.

Table 3. Domain prioritisation matrix. Scores: citizen impact 1–3 (higher = more citizens affected); legal barrier 1–3 (higher = more legislative change required); technical complexity 1–3; political feasibility 1–3 (higher = more resistance). Overall priority = impact $\times$ (4 – mean barrier score). The subtrahend 4 converts barriers (where 3 = highest resistance) into enablers, so that a domain scoring 3 on impact and 1 on all three barriers yields the maximum priority of $3 \times (4 - 1) = 9$.

Domain	Citizen impact	Legal barrier	Tech complexity	Political feasibility	Phase
Banking / KYC	3	2	2	1	1
Passport	3	1	1	1	1
Social protection	3	2	2	2	2
Tax / PAN	2	2	2	2	2
Land registry	2	3	3	3	2
Transport	2	2	2	1	2
Civil registration	2	2	2	2	2
Local government	3	1	3	2	3

Phase 1 domains: Passport and Banking/KYC. These score highest on citizen impact and lowest on legal barrier. Nepal’s e-passport (DoFP) nominally requires NID but overseas applicants may omit the NIN field [17], confirming the absence of real-time API verification; the fix is mandatory NIN verification at application with pre-populated demographic fields. For banking, NID has been mandatory for new account opening since January 2025, but no API gateway has been deployed; BAFIA 2017 requires amendment to permit NID-based e-KYC, after which a Citizen Identity Gateway API returning only requested attributes under citizen consent would reduce onboarding from days to minutes.

Phase 2 domains: Social Protection, Tax/PAN, Land Registry, Transport, and Civil Registration. The Social Security Fund already mandates NIN for contributor registration; the remaining gap is a unified Social Registry using NIN as the deduplication key, with mandatory fallback preserving benefit access via citizenship certificate—the domain the Supreme Court’s 2024 stay targeted directly [12]. For IRD, the Income Tax Act 2058 must be amended to enable NIN-PAN linkage; automatic PAN issuance on NID enrolment would close the current parallel-identifier problem. Land registry (LRIMS, 126 district offices [15]) requires NIN as the canonical owner identifier through

record-mapping migration, with the Land Revenue Act amended accordingly. Transport integration is already decided: Nepal committed in July 2024 to merge driving licence endorsements into the NID card [16], pending Motor Vehicles Act amendment. Civil registration (753 local bodies, paper-based CRVS) needs near-real-time CRVS-to-DoNIDCR synchronisation, with NIN assigned at birth linked to parents’ records.

Phase 3 domain: Local Government. Nepal’s 753 local bodies represent the hardest connectivity challenge. The proposed bridge is a three-step model: each ward office is provisioned with a lightweight browser-accessible node that queries the NID API for verification without storing data; certificates are issued locally but digitally signed with a ward-office credential, enabling QR-based verification offline; and intermittent connectivity is handled via 48-hour cached tokens that synchronise when online. This *verify-online, sign-locally, present-offline* model preserves identity integrity across Nepal’s connectivity landscape.

6. Proposed Architecture: The Nepal Civic Identity Stack

6.1 Architectural Rationale

The comparative analysis in Section 3 yields a clear design principle: centralised architectures achieve rapid scale but create irreversible single-point-of-failure risk. Because biometric credentials cannot be reissued after a breach, Nepal’s architecture must avoid that pattern. We propose a *federated interoperability model*: DoNIDCR maintains the foundational identity registry, but domain-specific data remains with source agencies and is exchanged only via secure APIs with citizen consent and full audit logging, following the X-Road pattern [1].

Four considerations specific to Nepal reinforce this choice. First, a biometric breach would be irreversible given Nepal’s nascent cybersecurity incident-response capacity. Second, agencies retain custody of their own data, improving institutional buy-in for integration. Third, the Supreme Court’s constitutional constraint is architecturally consistent with federation: NID authenticates users but does not displace existing legal identifiers. Fourth, federated architectures scale horizontally, which matters for 753 local bodies with variable connectivity.

6.2 The Federated Legibility Principle

The comparative evidence and Nepal-specific constraints together motivate the paper’s central theoretical contribution:

The Federated Legibility Principle. A national identity system achieves durable interoperability when it (1) makes citizens legible to the state through a foundational registry while (2) making the state legible to citizens through an auditable consent architecture, and (3) avoids irreversible centralisation risks that undermine trust before scale is achieved.

Formal mapping. The six architectural layers operationalise each condition directly: Layers 1–2 address condition (1) by maintaining the foundational registry and authentication service; Layer 5 addresses condition (2) through the citizen-facing consent dashboard and audit log; and the federated storage model across Layers 3–4 addresses condition (3) by ensuring no single breach can expose the full identity record.

Boundary conditions. The principle applies to contexts sharing three features: a foundational registry has been deployed (enrolment exists); cross-domain service integration is the immediate policy goal (not initial enrolment); and the political-legal environment is ambivalent—integration is desired but constitutional or institutional constraints limit coercive approaches. Nepal satisfies all three. The principle does *not* apply where enrolment itself is the primary challenge (the principle presupposes a registry to federate from) or where a single-agency use case dominates (federation overhead is not justified for a standalone application).

Differentiation from existing frameworks. The World Bank ID4D principles [21] specify normative requirements (universal, voluntary, privacy-respecting) but do not specify *architecture*. The DPI literature (Frischmann [29]) addresses infrastructure as commons but does not address the citizen-legibility condition. The Federated Legibility Principle adds a third structural condition—avoiding irreversible centralisation—that is absent from both frameworks and is motivated directly by the Design Hypotheses derived from the six-country comparison. It is offered as a design heuristic for fragile-federation contexts, subject to empirical validation through future comparative work.

6.3 Threat Model (STRIDE)

Table 4 applies the STRIDE methodology (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) to derive the threat model formally rather than asserting it.

6.4 Six-Layer Stack

Figure 1 illustrates the Nepal Civic Identity Stack. Each layer communicates with the layer immediately below it through the API gateway; no layer has direct access to Layer 1 except through Layer 2.

Layer 1 — Foundational Identity Registry. DoNIDCR maintains: the NIN; encrypted biometric templates stored separately from demographic data; the demographic record; and photograph. Raw biometric data is never exported via API; authentication returns a match-or-no-match response only.

Layer 2 — National NID Authentication Service (NNAS). Implements OIDC so that any authorised service receives a verified identity token upon citizen authentication. Modalities include biometric match, mobile OTP, QR-code offline verification, and digital signature. MOSIP provides an open-source implementation of this layer, with active deployments in the Philippines, Morocco, and Sri Lanka [23].

Table 4. STRIDE threat analysis for the Nepal Civic Identity Stack

Threat	Attack scenario	Architectural mitigation
Spoofing	Fraudulent relying party impersonates a bank to request citizen attributes	Mutual TLS + client-certificate authentication at Layer 3; only registered relying parties may call the gateway
Tampering	Man-in-the-middle modifies attribute values in transit	End-to-end signed JWTs; any tampering invalidates the token signature
Repudiation	Agency denies having accessed citizen data	Immutable, timestamped audit log at Layer 3; citizen-visible in Layer 5 dashboard
Information disclosure	Breach of a single agency node exposes all NID data	Federated storage: each node holds only its own domain data; no node holds the full NID record
Denial of service	API gateway flooded, blocking authentication for all services	Rate limiting and anomaly detection at Layer 3; 48-hour cached offline tokens for Layer 6
Elevation of privilege	Insider at one agency queries attributes outside their authorised scope	Per-request authorisation scoped to declared purpose; anomalous query patterns trigger real-time alert

Layer 3 — National API Gateway. Administered jointly by DoNIDCR and the National Information Technology Centre. Enforces per-request authentication and authorisation, rate limiting, standardised JSON exchange formats, real-time anomaly alerting, and immutable audit logging of all data access events.

Layer 4 — Federated Data Exchange. Each major agency (DoFP, IRD, NRB, DOLMA, DoTM, local bodies) deploys a data exchange node exposing domain-specific attributes via standardised APIs. A bank requesting KYC receives only the requested attributes after citizen consent—never the full NID record. All exchanges are end-to-end encrypted, mutually authenticated, and immutably logged, following the X-Road security server model [1].

Layer 5 — Consent Management. Integrated into the Nagarik App as a consent

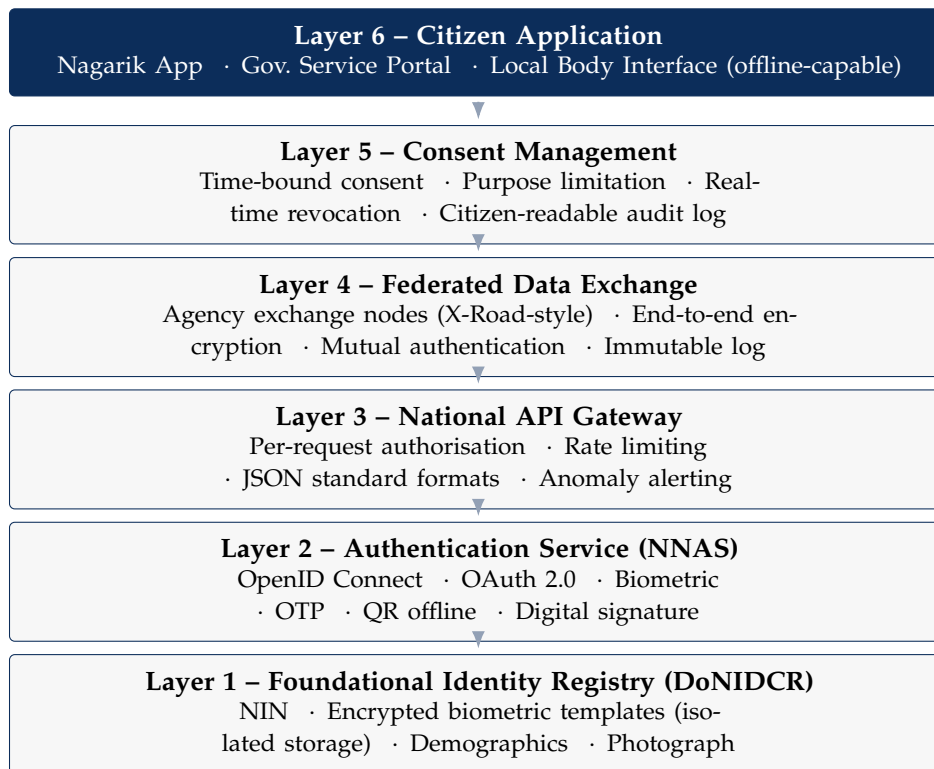


Figure 1. Nepal Civic Identity Stack: six-layer federated architecture. Arrows indicate the direction of service requests; all exchanges are bidirectional and logged at the gateway layer. No layer has direct access to Layer 1 except through Layer 2.

dashboard displaying all pending and historical data-sharing requests, providing time-bound and purpose-limited controls, showing a citizen-readable audit log of every agency access event, and supporting real-time consent revocation.

Layer 6 — Citizen Application. The Nagarik App serves as the primary interface: digital NID wallet, certificate retrieval, service portal, and consent dashboard. A Government Service Portal provides browser access. A simplified Local Body Interface suits municipalities with limited IT capacity, including offline operation for intermittent connectivity.

6.5 API Call Flow: Banking KYC

Figure 2 illustrates the call flow for a bank requesting KYC—the transaction most likely to drive daily adoption. If consent is denied at step 5, the flow terminates and the bank receives a standardised access-denied response with no attributes disclosed. A sample JSON token payload is given in Appendix A.

6.6 Recommended Open Standards

- **OpenID Connect (OIDC):** identity layer atop OAuth 2.0 enabling single sign-on across all integrated services.

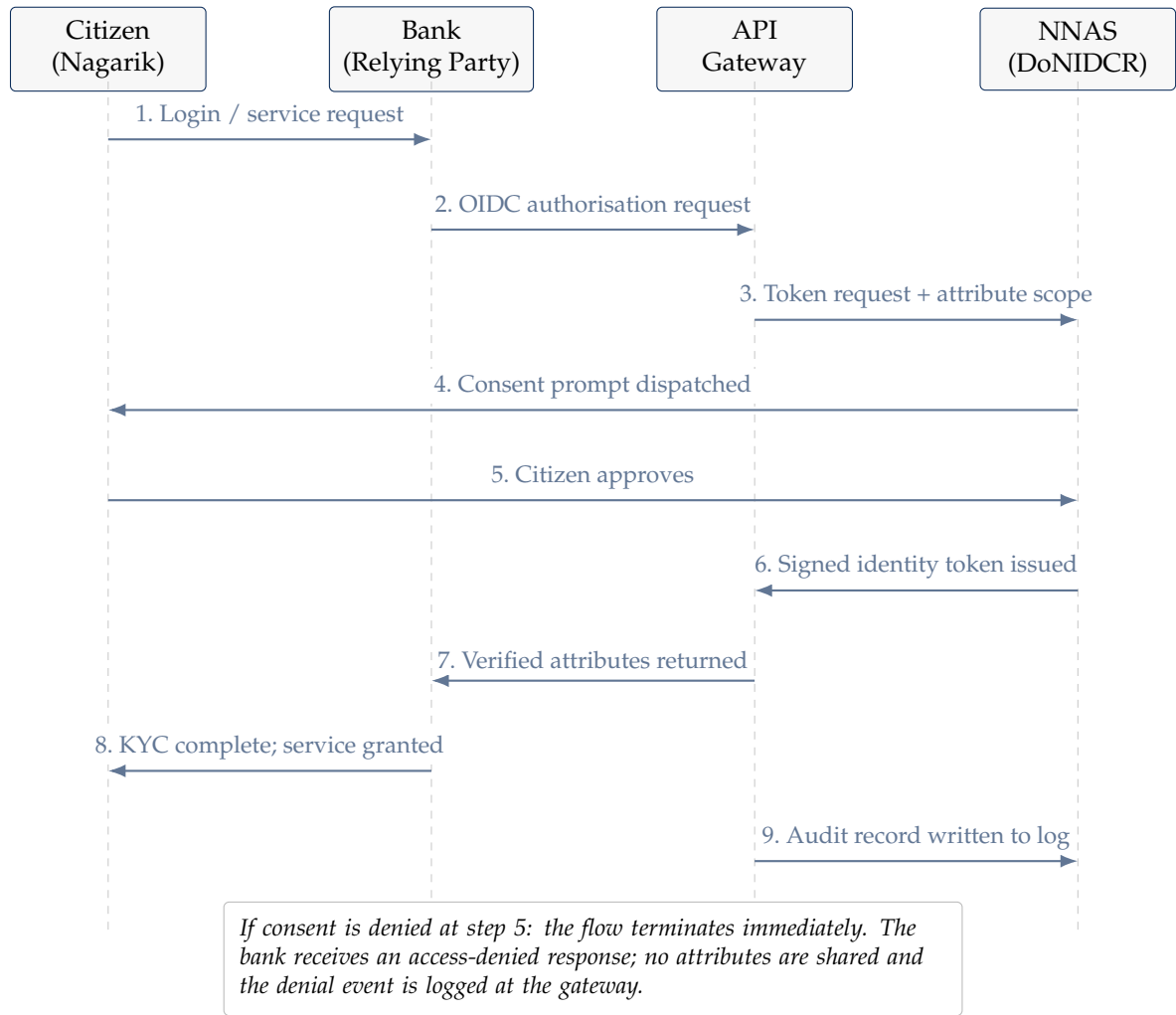


Figure 2. API call flow for banking KYC via the Nepal Civic Identity Stack. Steps 4–5 represent the consent exchange; the bank receives only the requested attributes and never has access to biometric templates or the full NID record. See Appendix A for a sample JSON identity token.

- **OAuth 2.0:** authorisation framework for delegated, consent-based API access.
- **FAPI 2.0:** financial-grade API profile for high-security government and financial transactions, adopted by Singapore’s Singpass.
- **MOSIP:** open-source foundational identity platform with active deployments in the Philippines, Morocco, and Sri Lanka; provides modular enrolment, lifecycle management, and e-KYC [23]. Nepal’s enrolment stack should evaluate MOSIP as the basis for DoNIDCR’s registry upgrade given its open governance and South/South-East Asia footprint.
- **X-Road:** federated data exchange protocol with open-source governance and demonstrated cross-border federation capability [1].
- **W3C Verifiable Credentials:** tamper-evident digital credentials (driving endorsements, civil certificates) held in the citizen’s digital wallet and verifiable offline.

6.7 Scalability, Latency, and Offline Operation

For 753 local bodies with intermittent connectivity, the architecture accommodates offline operation through two mechanisms. The Nagarik App caches a time-limited cryptographic token valid for 48 hours without network access. Local body exchange nodes queue outbound verification requests and deliver them when connectivity is restored. Expected API round-trip latency on a 4G connection is under 500 milliseconds for a name-and-date verification; biometric matching is estimated at 1–2 seconds, consistent with MOSIP deployment benchmarks [23]. NIN corrections propagate to all connected agencies within 24 hours. Death registration at the CRVS triggers automatic NIN deactivation. Identity disputes are escalated to DoNIDCR through a formal grievance mechanism with a 30-day resolution obligation.

6.8 Financial Sustainability and Operational Requirements

Long-term financial sustainability is a recurring failure point for DPI in developing nations [21]. The recommended model charges authorised private-sector relying parties a per-verification fee of NPR 10–15 (calibrated to NADRA’s commercial rate of USD 0.05–0.10), with government agencies zero-rated. For the utilisation assumption, two comparables are instructive: NADRA (Pakistan) processes approximately 500 million commercial verifications annually across 120 million registered citizens—roughly four per person per year [7]; Singapore’s Singpass reported approximately 1.7 billion authentications in 2023 across roughly four million eligible users, or approximately 425 per user per year, though the majority are low-cost mobile authentications [4]. Nepal’s early-stage ecosystem, limited private-sector integration, and lower smartphone penetration justify a figure well below both; three verifications per adult per year is adopted as the conservative floor, representing approximately 75 per cent below the NADRA rate. At this rate, the model generates approximately NPR 540M annually against estimated gateway operating costs of USD 0.5–1M, leaving a sustainable surplus. A production deployment must satisfy: 99.9% availability SLA for the API gateway; RTO of 4 hours and RPO of 15 minutes; data residency within Nepal’s jurisdiction; audit logs retained for 7 years; and TLS 1.3 minimum for all inter-node communication. These requirements should be codified in NID Integration Standards issued under Section 19 of the NID Act 2076.

7. Legal and Privacy Framework

7.1 Current Legal Landscape

Nepal’s primary privacy statute is the Privacy Act, 2075 (2018)—hereafter *Privacy Act 2075*—which prohibits arbitrary processing of sensitive personal data, requires consent for collection by public bodies, and grants citizens rights to access and correction [18]. The Act contains critical gaps: no independent enforcement authority; no mandatory breach notification; no biometric data governance provisions; no DPIA

requirements; no data portability rights. A World Bank assessment noted that many private-sector actors reference the EU GDPR rather than Nepal’s own law due to the lack of enforcement clarity [20].

The NID Act 2076 prescribes penalties for unauthorised data access but does not establish a consent architecture for cross-domain sharing, purpose-limitation principles, or an independent oversight body. The Draft Data Privacy and Personal Information Protection Act (2082 BS) [19] represents a significant step forward: it proposes a seven-member Data Protection Board with investigation and penalty powers, mandates breach notification within 72 hours, and introduces data minimisation requirements. However, the draft does not contain biometric-specific governance provisions equivalent to GDPR Article 9, does not establish a DPIA obligation for large-scale government processing, and its proposed maximum penalty of NPR 5 million—though a 100-fold increase over Privacy Act 2075—remains low relative to the scale of harms that a DoNIDCR-scale breach could cause. The paper recommends three targeted amendments to the draft: insertion of explicit biometric processing lawful bases, a mandatory DPIA for any NID integration exceeding 500,000 citizen records, and a penalty ceiling of 5% of the relevant agency’s annual operating budget.

7.2 Comparative Framework Analysis

Table 5 maps Nepal’s current law against the EU GDPR and India’s DPDP Act 2023. The penalty row uses GDP-per-capita normalisation to enable meaningful cross-jurisdictional comparison: raw currency figures are meaningless across economies of different sizes.

Table 5. Data protection framework comparison. Penalties are normalised to USD equivalent and as a multiple of annual GDP per capita (Nepal: USD 1,340; India: USD 2,390; EU average: USD 37,500) to enable cross-jurisdictional comparison.

Feature	Nepal 2075	India DPDP	EU GDPR
Independent regulator	None	DPB	DPAs
Breach notification	Not required	Required	72 hrs
Biometric governance	Basic	Specific	Article 9
DPIA requirement	None	Not explicit	Article 35
Data portability	None	Partial	Article 20
Consent framework	Basic	Explicit	Specific, withdrawable
Max penalty (raw)	NPR 50,000	INR 250 crore	EUR 20M / 4% turnover
Max penalty (USD equiv.)	USD 385	USD 30M	USD 22M
Penalty / GDP per capita	0.29×	12,552×	587×

The normalised comparison reveals that Nepal’s Privacy Act 2075 penalty is effectively negligible—less than one-third of GDP per capita, compared to over 12,000 times

GDP per capita for India’s DPDP. This is not merely a paper deficiency: it means that any commercial actor calculating breach risk versus compliance cost will rationally choose under-compliance. Effective deterrence requires a penalty floor of at least $100 \times$ GDP per capita (approximately NPR 17M at current rates), rising to 1% of annual organisational revenue for repeated violations.

Privacy Act 2075 must be amended to: establish an independent Data Protection Commission with investigation, audit, and fining powers; mandate breach notification within 72 hours; define explicit lawful bases for biometric data processing (GDPR Article 9 standard); codify portability, erasure, and objection rights; require DPIAs for all NID integration deployments; and raise maximum penalties to a credible deterrence level.

NID Act 2076 must be amended to: insert purpose-limitation clauses restricting NID data to identity verification; require data minimisation at the attribute level; mandate citizen-readable consent receipts for every data access event; establish retention sunset clauses; and require independent annual security audits of DoNIDCR systems.

Sectoral laws requiring amendment: Passport Act (recognise NIN as primary identifier); BAFIA 2017 (permit NID-based e-KYC); Income Tax Act 2058 (enable NIN-PAN linkage with consent); Motor Vehicles Act (NID card as driving licence); Local Government Operation Act (mandate NID integration standards).

7.3 Coercive Consent and Contextual Integrity

The “coercive consent” risk deserves extended analysis, as it is the most legally significant privacy vulnerability in the proposed integration. Nissenbaum’s contextual integrity framework holds that privacy norms are violated not merely when data is disclosed, but when information flows cross contextual boundaries in ways that violate the norms of the originating context [32]. In Nepal’s case: a citizen who shares biometric data with DoNIDCR for identity enrolment has consented to that specific context. Any subsequent use of that data for tax investigation, benefit eligibility determination, or behavioural analytics constitutes a context-crossing information flow that violates contextual integrity—regardless of whether a generic “consent to NID integration” checkbox was ticked.

Solove’s taxonomy of privacy violations further clarifies the risk: the aggregation problem holds that combining individually innocuous data points—name from NID, transaction history from IRD, location from DoTM, benefit status from SSF—produces a profile more privacy-invasive than any single element [33]. This is precisely what an integrated NIN-as-universal-identifier system enables if purpose-limitation is not enforced at the API layer.

The proposed Layer 3 gateway addresses this through attribute-scoped authorisation: each relying party may only request the specific attributes declared in its registration, and any query outside that scope is rejected without reaching the foundational registry.

This is a technical implementation of contextual integrity.

8. Implementation Roadmap

The roadmap is sequenced to address highest-impact, lowest-legal-barrier integrations first while building the governance foundations on which later phases depend. The domain prioritisation matrix in Table 3 determines sequencing; Phases 2 and 3 do not commence unless Phase 1 KPIs (Table 6) are met.

Phase 1 (Years 1–2): Foundation. Enact the Data Privacy and Personal Information Protection Act; amend the NID Act to insert consent architecture and purpose-limitation clauses; establish an independent Data Protection Commission; deploy the National API Gateway and NNAS with OIDC; complete the passport-NID API integration; mandate NRB e-KYC via the Citizen Identity Gateway API; achieve 50 per cent physical card delivery.

Phase 2 (Years 3–4): Federated Exchange. Deploy X-Road-style exchange nodes across IRD, DOLMA, and SSF; complete the LRIMS-NID linkage; implement the unified Social Registry with NIN deduplication; integrate DoTM driving licence endorsements; launch the Consent Dashboard in the Nagarik App; achieve 75 per cent card delivery or Nagarik App NIN activation.

Phase 3 (Years 5–7): Universal Coverage. Deploy exchange nodes to all 753 local bodies; implement birth-NIN assignment from civil registration; achieve 95 per cent adult NIN activation; review and update all sectoral laws; publish annual privacy impact reports and citizen data-access statistics.

Table 6. Measurable KPIs by phase

KPI	Phase 1 target	Phase 2 target	Phase 3 target
NID card delivery rate (of enrolled)	≥50%	≥75%	≥95%
Integrated service domains	2 (passport, banking)	6	8
API gateway uptime (monthly avg.)	≥99.5%	≥99.9%	≥99.9%
Citizen audit portal active users	Launched	≥500K	≥5M
Reported exclusion incidents / month	Baseline set	≤500	≤100
Data Protection Commission operational	Yes	Active	Annual report published

Governance accountability should sit with: DoNIDCR and NITC for technical deployment (Parliamentary IT Committee oversight); an independent Data Protection Commission for privacy enforcement with annual public reporting; and a DoNIDCR Grievance Cell for citizen disputes with a statutory 30-day resolution obligation. The principal implementation risks—political budget cuts, cybersecurity incidents, and Supreme Court challenge to expanded mandates—are mitigated respectively by the statutory

Commission reporting obligation, mandatory public disclosure within 72 hours of incidents, and the phased rollout gated on 75% card delivery before Phase 2 expansion.

9. Policy Recommendations

Each recommendation below is addressed to a specific actor and grounded explicitly in evidence from the comparative analysis or the Nepal-specific findings above.

1. **Parliament: Enact data protection legislation before expanding mandatory integration.** The Supreme Court’s 2024 jurisprudence and the India/Bangladesh exclusion cases confirm that mandatory NID use without adequate legal safeguards creates both constitutional exposure and real exclusion harm. An independent Data Protection Commission must be operational and adequately resourced before Phase 2 proceeds. The Draft Data Privacy Act 2082 BS should be enacted in the current parliamentary session with the three amendments specified in Section 7.
2. **DoNIDCR: Adopt federated, not centralised, architecture.** Design Hypothesis H1 from the comparative analysis holds: all documented major breaches in the six-country sample occurred in centralised systems. The irreversibility of biometric credential compromise makes this the highest-stakes architectural decision Nepal will make. The X-Road pattern provides proven, open-source, and interoperability-tested infrastructure.
3. **DoNIDCR: Achieve 75 per cent card delivery before expanding mandates.** The Supreme Court’s 2024 stay was grounded in exactly this threshold argument. Mandating NID for additional services while the majority of enrolled citizens lack their cards replicates the exclusion risk the Court identified. Rwanda’s door-to-door agent model, adapted to Nepal’s ward-level facilitator network, is the operationally demonstrated route to accelerating delivery.
4. **Parliament / MoHA: Mandate fallback mechanisms in every integration law.** Every NID-integrated service must preserve access via citizenship certificate until NID coverage reaches 95 per cent of adults. This should be codified as a statutory requirement in each sectoral amendment rather than left to administrative discretion. Contextual integrity (Section 7) requires that consent not be coercive.
5. **NRB / MoF: Open the ecosystem to authorised private-sector relying parties.** Singapore’s Singpass demonstrates (Design Hypothesis H2) that private-sector integration with transparent citizen audit rights increases voluntary adoption rates and generates API revenue sufficient to cover infrastructure costs. Even a conservative adoption scenario of three verifications per adult per year at NPR 10 generates approximately NPR 540M—more than covering gateway operating costs.
6. **DoNIDCR / Local governments: Deploy ward-level digital facilitators.** Rwanda’s agent network reduced average service delivery time from five days to 24 hours. Nepal’s 753 local bodies represent the hardest inclusion challenge; ward-level

facilitators trained on the Nagarik App are the operationally proven solution for the offline-first connectivity environment described in Section 5.

7. **Parliament: Guarantee citizen audit rights as a statutory entitlement.** Estonia’s experience—the highest voluntary adoption rate among the six cases—shows that transparency by default builds trust more effectively than privacy policies. Every citizen should have an enforceable right to view every data access event associated with their NIN, revoke any consent in real time, and receive a machine-readable audit log on request. This right should sit in the NID Act, not in administrative guidelines.
8. **Civil society and academic institutions: Establish independent oversight.** This recommendation is conspicuously absent from most government integration plans. An independent NID Civil Society Oversight Panel—comprising legal scholars, technologists, and citizen representatives—should be mandated by the Data Protection Commission to conduct annual audits of integration coverage, exclusion incidents, and consent dashboard usage. Academic institutions should be given API access to anonymised, aggregated audit data for independent research.

10. Conclusion

If Nepal’s political bandwidth allows only a single legislative action before the next integration mandate expansion, it should be **enacting the Data Protection Commission with real enforcement powers**. This is the single highest-leverage reform because it simultaneously creates the oversight architecture that makes all other reforms credible, provides a legal mechanism to enforce the fallback requirements that prevent exclusion, establishes the GDP-normalised penalty deterrent that changes commercial actors’ compliance calculus, and satisfies the constitutional condition implicit in the Supreme Court’s 2024 jurisprudence on Article 28 and Article 17. Every other reform in this paper is either downstream of this one or can be achieved administratively. The Commission cannot.

Nepal’s NID project stands at an inflection point. The enrolment infrastructure exists; the Nagarik App has substantial reach; the legal framework has passed constitutional scrutiny; and the World Bank DPI investment signals institutional momentum. What is absent is the interoperability layer that transforms 17 million enrolments into a functional civic identity infrastructure.

This paper has argued for what we term the *Federated Legibility Principle*: a national identity system achieves durable interoperability when it (1) makes citizens legible to the state through a foundational registry while (2) making the state legible to citizens through an auditable consent architecture, and (3) avoids the irreversible centralisation risks that undermine trust before scale is achieved. The Nepal Civic Identity Stack operationalises this principle through six layers, two propositions derived from comparative evidence, and a three-phase implementation roadmap with measurable KPIs and a

governance structure that ensures accountability rather than assuming it.

The potential benefits are concrete. Estonia saves 2,589 person-years of administrative time annually through X-Road [2]; Rwanda reduced average service delivery times by 80 per cent through IremboGov [9]; Singapore reduced bank onboarding costs by USD 36 per customer through Singpass [4]. Nepal possesses the preconditions for comparable outcomes. Whether those outcomes materialise depends not on the quality of the architecture but on the political will to enact the Data Protection Commission before expanding mandatory NID integration—the single reform from which all others follow.

Limitations

This paper has four significant limitations that future work should address.

Absence of primary data. Table 1 rests on indicative estimates from secondary sources. A structured primary study—even 20 semi-structured interviews with DoNIDCR staff, ward office workers, bank KYC officers, and rural citizens—would transform the burden model from illustrative to evidential and would reveal institutional resistance patterns that secondary sources cannot capture.

Single-country focus. The paper argues from Nepal’s specific constitutional and institutional context. The Federated Legibility Principle is offered as a transferable framework, but its applicability to other fragile-federalism contexts (Ethiopia, Pakistan, Myanmar) is asserted rather than demonstrated. Cross-country comparative application is a priority for subsequent research.

Rapidly changing legal landscape. Nepal’s Draft Data Privacy Act 2082 BS, the Cabinet mandate timelines, and the Supreme Court jurisprudence were all in flux during the writing of this paper. Readers should verify the current status of these instruments, as legislative developments may have overtaken specific recommendations.

Technical estimates without deployment data. The latency, scalability, and financial sustainability figures rest on comparable deployments (MOSIP in Philippines, Singpass in Singapore) rather than Nepal-specific pilots. A phased pilot deployment—even a single ward-level node integrated with one agency—would provide the empirical grounding the architecture section currently lacks.

Data Availability

The enrolment and card-collection statistics cited in this paper are drawn from publicly accessible government and media sources: DoNIDCR operational reports as relayed by *The Rising Nepal* [11] (retrieved May 2025) and Biometric Update [10] (retrieved May 2025). The Nagarik App install figures are sourced from the official Nagarik App portal [13]. No proprietary or restricted datasets were used. All URLs in the reference list were verified accessible as of June 2025; readers should note that Nepal’s legal landscape (Draft Data Privacy Act 2082 BS, Cabinet integration mandates) was in active

development at that date and may have changed since. The legal analysis reflects the state of instruments as of June 2025.

Acknowledgements

The author thanks the anonymous reviewers who provided pre-submission feedback on earlier drafts, and members of the Dev Community Nepal developer network for discussions on the practical constraints of Nagarik App integration. The author is solely responsible for all errors of fact and judgement. This research received no institutional or external funding.

Conflict of Interest

The author declares no conflict of interest. No funding was received for this research.

References

- [1] e-Estonia. X-Road: data exchange layer for information systems. <https://e-estonia.com/solutions/interoperability-services/x-road/>, 2025.
- [2] Nortal. Why digital sovereignty matters and how X-Road makes it happen. <https://nortal.com/insights/why-digital-sovereignty-matters-and-how-x-road-makes-it-happen>, 2024.
- [3] Unique Identification Authority of India. Aadhaar authentication ecosystem. <https://uidai.gov.in/en/ecosystem/authentication-ecosystem.html>, 2025.
- [4] Ministry of Digital Development and Information, Singapore. Singpass factsheet. <https://www.mddi.gov.sg/newsroom/singpass-factsheet-02032022>, 2022.
- [5] Biometric Update. Singapore wants to share its learnings on digital ID. <https://www.biometricupdate.com/202210/singapore-wants-to-share-its-learnings-on-digital-id-so-does-world-bank>, 2022.
- [6] Aratek Biometrics. Improving Bangladesh national identity card registration. <https://www.aratek.co/case-studies/improve-bangladesh-national-identity-card-registration-with-advanced-fingerprint-scanners>, 2025.
- [7] TechJuice. Data leak saga, privacy concerns cast shadow over Jazz-NADRA collaboration. <https://www.techjuice.pk/data-leak-saga-privacy-concerns-cast-shadow-over-jazz-nadra-collab/>, 2025.
- [8] Dawn. Pakistan's Digital Nation Act 2025: key provisions and data exchange framework. <https://www.dawn.com/news/1895234>, 2025.
- [9] Digital Impact Alliance. Integrated national data exchange systems: Rwanda case study. <https://dial.global/research/integrated-national-data-exchange-rwanda-case-study/>, 2024.

- [10] Biometric Update. Nearly 66% of Nepal citizens have not collected national ID cards. <https://www.biometricupdate.com/202505/nearly-66-of-nepal-citizens-have-not-collected-national-id-cards>, 2025.
- [11] The Rising Nepal. NID enrolment and card collection statistics. <https://risingnepaldaily.com/news/61395>, 2025.
- [12] Sharesansar. Supreme Court temporarily halts mandatory NID for public services. <https://www.sharesansar.com/newsdetail/supreme-court-temporarily-halts-governments-decision-to-mandate-national-id-for-public-services-and-social-security-allowances-2024-08-25>, 2024.
- [13] Government of Nepal. Nagarik App: NID integration and service catalogue. <https://nagarikapp.gov.np/>, 2025.
- [14] Department of National ID and Civil Registration. National Identity Card and Civil Registration Act, 2076. <https://donidcr.gov.np/content/17/national-identity-card-and-registration-act--2076/>, 2025.
- [15] Department of Land Management and Archive. Land Records Information Management System: district coverage. Government of Nepal, 2024.
- [16] Department of Transport Management. Driving licence integration with NID card. Government of Nepal Gazette, July 2024.
- [17] Permanent Mission of Nepal to the UN, Geneva. Passport information: NID field requirements. <https://gva.nepalmission.gov.np/pages/passport/>, 2025.
- [18] Nepal Law Commission. Privacy Act, 2075 (2018). <https://lpr.adb.org/sites/default/files/resource/%5Bnid%5D/nepal-the-privacy-act-2075-2018-english.pdf>, 2018.
- [19] Ministry of Communication and Information Technology, Nepal. Draft Data Privacy and Personal Information Protection Act, 2082 BS. Government of Nepal, 2025.
- [20] World Bank. Use of data in the private sector of Nepal. <https://documents1.worldbank.org/curated/en/805261601023506163/pdf/>, 2020.
- [21] World Bank. Nepal Digital Public Infrastructure Investment Project. World Bank Project Documentation, 2025.
- [22] UN Department of Economic and Social Affairs. E-Government Survey 2024: Nepal country data. <https://publicadministration.un.org/egovkb/en-us/Data/Country-Information/id/120-Nepal>, 2024.
- [23] MOSIP. Modular Open Source Identity Platform: technical documentation. <https://docs.mosip.io/>, 2025.
- [24] Chambers. Digital personal data under the DPDP Act. <https://chambers.com/articles/digital-personal-data-under-the-dpdp-act-what-data-does-it-cover>, 2023.
- [25] LibTech India. Aadhaar-based biometric authentication failures and PDS exclusions. <https://libtech.in>, 2019.

- [26] Alan Turing Institute. Open standards for interoperability between identity systems. https://www.turing.ac.uk/sites/default/files/2025-01/wp_1_open_standards_open_specifications_and_open-source_approaches_for_interoperability_between_identity_systems_jyotsna_-_final_0.pdf, 2025.
- [27] HSRC Ghana. Integration and interoperability of national identification systems. <https://www.hsrbgh.org/wp-content/uploads/2024/09/Integration-and-Interoperability-of-National-Identification-Systems.pdf>, 2024.
- [28] J. C. Scott. *Seeing Like a State: How Certain Schemes to Improve the Human Condition Have Failed*. Yale University Press, 1998.
- [29] B. M. Frischmann. *Infrastructure: The Social Value of Shared Resources*. Oxford University Press, 2012.
- [30] L. Dencik, A. Hintz, J. Cable. Towards data justice? The ambiguity of anti-surveillance resistance in political activism. *Big Data & Society*, 3(2):1–12, 2016. <https://doi.org/10.1177/2053951716679678>.
- [31] P. Dunleavy, H. Margetts, S. Bastow, J. Tinkler. *Digital Era Governance: IT Corporations, the State, and e-Government*. Oxford University Press, 2006.
- [32] H. Nissenbaum. *Privacy in Context: Technology, Policy, and the Integrity of Social Life*. Stanford University Press, 2010.
- [33] D. J. Solove. A taxonomy of privacy. *University of Pennsylvania Law Review*, 154(3):477–560, 2006. <https://doi.org/10.2307/40041279>.

A. Sample API Contract: OIDC Token Exchange

This appendix provides a representative API contract for the banking KYC flow described in Section 6. All values are illustrative; a production deployment would specify exact scopes, error codes, and security parameters in a formal OpenAPI 3.0 specification maintained by DoNIDCR.

A.1 Token Request (HTTP POST)

The relying party (bank) exchanges the authorisation code received after citizen consent for an identity token:

Listing 1. OIDC token request — Citizen Identity Gateway

```
POST /oauth/token HTTP/1.1
Host: idp.nid.gov.np
Content-Type: application/x-www-form-urlencoded

grant_type=authorization_code
&code=eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...
&redirect_uri=https%3A%2F%2Fkyc.bankname.com.np%2Fcallback
&client_id=bankname_kyc_app
&client_secret=<hashed_secret>
&scope=openid%20profile%3Aname%20profile%3Adob%20profile%3Aphoto
```

A.2 Identity Token Response (JSON)

The NNAS returns a signed JWT identity token and an access token:

Listing 2. OIDC token response — NNAS (DoNIDCR)

```
HTTP/1.1 200 OK
Content-Type: application/json

{
  "token_type": "Bearer",
  "expires_in": 300,
  "access_token": "eyJhbGciOiJSUzI1NiJ9...",
  "id_token": "eyJhbGciOiJSUzI1NiJ9...",
  "scope": "openid profile:name profile:dob profile:photo"
}
```

A.3 Decoded Identity Token Payload

The JWT `id_token` payload carries only the attributes explicitly requested and consented to. The bank never receives biometric templates, NIN in plain text (only a subject identifier), or attributes outside the consented scope:

Listing 3. Decoded JWT payload — illustrative identity token

```
{
  "iss": "https://idp.nid.gov.np",
  "sub": "nid-sub-c3ab8ff13720e8ad9047dd39466b3c89",
  "aud": "bankname_kyc_app",
  "exp": 1720000500,
```

```
{
  "iat": 1720000200,
  "auth_time": 1720000195,
  "acr": "urn:nid:loa:2",
  "name": "Hari Prasad Sharma",
  "birthdate": "1985-04-12",
  "picture": "https://idp.nid.gov.np/photo/c3ab8f...jpg",
  "consent_ref": "c9d4e2a7-1f38-4b56-a091-83ed2ef9b3d1",
  "jti": "3f6b9c12-ee45-4120-a83d-1b7e9d4f0c22"
}
```

Design notes: The `sub` field is a pairwise pseudonymous identifier unique to the bank-citizen pair; the bank cannot use it to correlate across agencies. The `picture` URL is time-limited and HTTPS-only. The `consent_ref` field links the token to the specific citizen consent event recorded in the audit log (Layer 5). Biometric templates are never included in any API response.